

Control ID	Risk ID	Risk Domain	Control Objective	Control Description	Control Type	Control Nature	Frequency	Control Owner	Audit Procedure	Evidence Required	Design Assessment	Control Gap
C-001	R-001	Identity & Access Management	Ensure only authorized customers can access brokerage accounts.	Customers must complete system-enforced MFA before account access is granted.	Preventative	Automated	Per Login	Information Security / IAM	Check MFA settings and review a sample of customer logins to confirm MFA was required.	MFA settings; login logs; sample login records	Partially Effective	Step-up authentication is not consistently required for high-risk account changes such as adding a new bank account or modifying customer contact information.
C-002	R-002	Transaction & Fraud Controls	Prevent unauthorized money movement to unverified bank accounts.	New external bank accounts undergo ownership verification and customers receive notifications of bank-account changes.	Preventative	Automated	Per Change	Fraud Risk / Brokerage Operations	Review a sample of bank-account changes to confirm ownership checks and customer notifications were completed.	Bank verification logs; account-change logs; customer notifications	Partially Effective	Step-up authentication is not required before adding a new external bank account, and withdrawals may be initiated shortly after the account change.
C-003	R-003	Identity & Access Management	Limit employee and administrator access to approved job responsibilities.	RBAC, manager approval, termination deactivation, and periodic user-access reviews are used to manage privileged access.	Detective	IT-Dependent Manual	Quarterly	IAM / IT Operations	Review employee access and confirm users only have appropriate permissions and terminated employees were removed.	User-access list; access review records; termination report	Partially Effective	Periodic access reviews are not performed consistently, increasing the risk that employees who change roles or leave the organization may retain unnecessary or privileged access.
C-004	R-004	Logging & Monitoring	Detect and investigate suspicious activity across critical brokerage systems.	Critical systems send authentication, administrative, and transaction activity to centralized security monitoring for alert review.	Detective	IT-Dependent Manual	Continuous/Daily	Security Operations	Check which systems send logs to monitoring and review a sample of high-risk alerts to confirm they were investigated.	SIEM source list; alert logs; investigation records	Partially Effective	Logging coverage is inconsistent across critical systems, and alerts for high-risk administrative and customer-account activity are not reviewed within a defined timeframe.
C-005	R-005	Trade Processing & Operations	Ensure trade orders are valid and not unintentionally duplicated before execution.	The Order Management System performs automated order validation and duplicate-order checks before routing trades.	Preventative	Automated	Per Transaction	Trading Technology / Brokerage Operations	Review trade-order controls and sample orders to confirm validation and duplicate-order checks worked.	OMS settings; order logs; duplicate/rejected order records	Partially Effective	Trade execution records are not reconciled to internal order records in near real time, increasing the risk that failed, duplicated, or incorrectly recorded trades may not be identified promptly.
C-006	R-006	Data Protection & Privacy	Restrict unnecessary exposure of sensitive customer information.	Sensitive customer fields are masked by default and access to full information is restricted by role and logged.	Preventative	Automated	Continuous	Information Security / Data Protection	Review data-masking and employee-access settings to confirm sensitive customer data is restricted.	Role/permission list; masking settings; access logs	Partially Effective	Customer-support personnel can view certain sensitive customer information in full even when the information is not required to perform routine support responsibilities.
C-007	R-007	Change Management	Ensure production changes are authorized, tested, and recoverable.	Production changes require documented requests, testing, approval, and rollback procedures before deployment.	Preventative	IT-Dependent Manual	Per Change	Technology / Change Management	Review a sample of system changes to confirm they were approved, tested, and had rollback plans before release.	Change tickets; approvals; test results; deployment records	Partially Effective	Emergency production changes may be implemented before independent approval and are not consistently subjected to documented post-implementation review.
C-008	R-008	Third-Party Risk	Ensure critical third parties maintain appropriate operational and security controls.	Vendors undergo risk-based due diligence, contractual review, and periodic assessment of control reports.	Preventative	Manual	Onboarding/Annual	Third-Party Risk / Procurement	Review a sample of critical vendors to confirm due diligence and periodic risk reviews were completed.	Vendor list; risk assessments; contracts; SOC reports	Partially Effective	Critical vendors are not consistently classified by risk level, and periodic reassessments are not completed for all providers that support sensitive data or critical brokerage operations.
C-009	R-009	Business Continuity & Resilience	Ensure critical systems and data can be restored after disruption.	Backups and periodic disaster-recovery exercises are used to validate restoration of critical brokerage systems and data.	Corrective	IT-Dependent Manual	Semiannual	Business Continuity / Technology	Review the latest disaster-recovery test and confirm systems/data were restored within expected recovery targets.	DR plan; backup logs; test results; recovery times	Partially Effective	Disaster-recovery testing is performed inconsistently and does not fully validate the recovery of critical brokerage processes, customer data, and dependencies on third-party service providers.
C-010	R-010	Trade Processing & Operations	Detect and resolve differences between internal and external transaction records.	Daily reconciliation compares internal transaction records with external records and generates exceptions for review.	Detective	IT-Dependent Manual	Daily	Brokerage Operations / Finance Operations	Review daily reconciliation reports and follow selected mismatches until they were investigated and resolved.	Reconciliation reports; exception logs; aging reports; review signoffs	Partially Effective	Certain reconciliation exceptions may remain unresolved beyond established review periods, and escalation requirements for aging exceptions are not consistently documented.
C-011	R-011	Vulnerability & Patch Management	Identify and remediate security vulnerabilities within established timelines.	Automated vulnerability scanning identifies weaknesses and tracks remediation based on severity.	Detective	Automated	Weekly	Information Security / Technology Operations	Review a sample of High/Critical vulnerabilities and confirm they were fixed within required timelines.	Vulnerability reports; remediation tickets; SLA rules; risk-acceptance records	Partially Effective	Establish formal escalation procedures for overdue high-risk vulnerabilities, require documented remediation or approved risk acceptance, and provide management with periodic reporting on outstanding vulnerabilities.
C-012	R-012	Market Data & Customer Experience	Detect delayed or stale customer-facing market data.	Automated monitoring identifies delayed market-data feeds and generates alerts when freshness thresholds are exceeded.	Detective	Automated	Continuous	Market Data Operations / Technology	Review market-data monitoring settings and sample stale-data events to confirm alerts were generated.	Monitoring settings; alert logs; incident records	Partially Effective	Customer-facing applications do not consistently display a clear warning when market-data updates are temporarily delayed.